

# Pflichtenheft – Service: auth-service

---

## Konsolidierte und korrigierte Endfassung

| Feld                          | Wert                                                                                                         |
|-------------------------------|--------------------------------------------------------------------------------------------------------------|
| Service                       | auth-service                                                                                                 |
| Version                       | 2.1                                                                                                          |
| Stand                         | 07.03.2026                                                                                                   |
| Technologie                   | Java 21, Spring Boot, Maven, REST/JSON, Spring Data JPA, Hibernate, Flyway, OpenAPI/Swagger, Docker optional |
| Datenbank                     | MySQL/MariaDB                                                                                                |
| API Context Path              | /api/v1                                                                                                      |
| Effektive Basis-URL (Default) | http://<host>:8101/api/v1                                                                                    |
| API/Application               | AUTH_SERVER_PORT (Default 8101)                                                                              |
| Management/Actuator           | AUTH_MANAGEMENT_SERVER_PORT (Default 8201)                                                                   |

## **1. Inhaltsverzeichnis**

- 1. Ziel und Zweck
- 2. Abgrenzung
  - 2.1 Enthalten
  - 2.2 Nicht enthalten
- 3. Systemkontext / Abhängigkeiten
  - 3.1 Inbound (wer ruft auth-service auf)
  - 3.2 Outbound (wen nutzt auth-service)
  - 3.3 Verantwortlichkeiten (Source of Truth)
  - 3.4 Datenflüsse
    - 3.4.1 Registrierung / Tenant-Bootstrap
    - 3.4.2 Login / MFA / Session
    - 3.4.3 Recovery / Cleanup / Retry
- 4. Begriffe
- 5. IAM-Absicherung und Mandantentrennung
  - 5.1 Grundprinzip
  - 5.2 JWT-Contract
  - 5.3 Tenant-Kontext und Konsistenzprüfungen
  - 5.4 Autorisierung über Rollen-/Admin-Logik
- 6. REST-API – Übersicht
  - 6.1 Basis-URL, Versionierung, Content Types
  - 6.2 Endpunkte
  - 6.3 Standard-Query
- 7. Funktionale Anforderungen
  - 7.1 Registrierung starten
  - 7.2 E-Mail verifizieren
  - 7.3 MFA Enrollment starten / bestätigen
  - 7.4 Aktivierung User / Company / IAM
  - 7.5 Login / MFA Verify
  - 7.6 Refresh Session

## 7.7 Logout

## 7.8 Passwort vergessen / Passwort zurücksetzen / Passwort ändern

## 7.9 MFA Recovery

## 7.10 Service-Token ausstellen

## 7.11 Beziehungen / Referenzmodell

## 8. Datenmodell

### 8.1 AuthCredential

### 8.2 AuthIdentity

### 8.3 RegistrationProcess

### 8.4 MfaConfig

### 8.5 RefreshSession

### 8.6 VerificationToken

### 8.7 PasswordResetToken

### 8.8 MfaRecoveryToken

### 8.9 IdempotencyRecord

### 8.10 JwtKeyMetadata

### 8.11 Persistenz- und Migrationsregeln

## 9. Idempotency-Regeln

## 10. Fehlerformat, Statuscodes, Fehlercodes

### 10.1 Fehlerformat

### 10.2 Fehlercode-Mapping

## 11. Betrieb / Deployment / Konfiguration

### 11.1 Serviceeigene Ports

#### 11.1.1 API/Application Port

#### 11.1.2 Management/Actuator Port

#### 11.1.3 Optionale Ports

#### 11.1.4 Regel bei parallelem Betrieb mehrerer Services auf einem Host

### 11.2 Pfad-Konfiguration

### 11.3 JWT-Konfiguration

### 11.4 Umgebungsvariablen

11.5 Logging, Audit und Nachvollziehbarkeit

11.6 Support-Diagnosezugriffe und Tenant-bezogene Auswertung

11.7 Datenschutz, DSGVO, Lösch- und Aufbewahrungsregeln

12. Tests und Abnahmekriterien

12.1 Tests

12.2 Abnahmekriterien

## 2. 1. Ziel und Zweck

Der auth-service muss die zentrale Authentifizierung innerhalb einer mandantenfähigen Plattform bereitstellen.

| Bereich              | Beschreibung                                                                                  |
|----------------------|-----------------------------------------------------------------------------------------------|
| Registrierung        | Der Service muss Registrierungen entgegennehmen und verarbeiten.                              |
| Social Registrierung | Der Service muss Registrierungen über Google und Facebook unterstützen.                       |
| Tenant-Bootstrap     | Der Service muss beim ersten Benutzer die Initialanlage des Mandanten fachlich orchestrieren. |
| E-Mail-Verifikation  | Der Service muss E-Mail-Verifikationen durchführen.                                           |
| MFA / 2FA            | Der Service muss eine von außen konfigurierbare 2FA-/MFA-Funktion unterstützen.               |
| Login                | Der Service muss Passwort-Login sowie Social Login über Google und Facebook unterstützen.     |
| Session-Verwaltung   | Der Service muss Refresh-Sessions verwalten.                                                  |
| Logout               | Der Service muss die aktuelle Session widerrufen können.                                      |
| Recovery             | Der Service muss Passwort-Reset und MFA-Recovery unterstützen.                                |
| JWT                  | Der Service muss JWT-Access-Tokens ausstellen.                                                |
| JWKS                 | Der Service muss öffentliche Signaturschlüssel bereitstellen.                                 |
| Service-Tokens       | Der Service muss kurzlebige interne Service-Tokens ausstellen.                                |
| Kompatibilität       | Der Service muss mit IAM, User und Company technisch konsistent zusammenarbeiten.             |

## 3. 2. Abgrenzung

### 2.1 Enthalten

| Bereich                                                         | Muss enthalten sein |
|-----------------------------------------------------------------|---------------------|
| Benutzer-Authentifizierung                                      | Ja                  |
| Registrierung mit PENDING-Zustand                               | Ja                  |
| Social Registrierung über Google                                | Ja                  |
| Social Registrierung über Facebook                              | Ja                  |
| E-Mail-Verifikation bei Registrierung                           | Ja                  |
| konfigurierbare 2FA / MFA                                       | Ja                  |
| TOTP als zweiter Faktor                                         | Ja                  |
| E-Mail als konfigurierbarer Kanal für Verifikation und Recovery | Ja                  |
| SMS als konfigurierbarer Kanal für Recovery                     | Ja                  |
| Passwort-Login                                                  | Ja                  |
| Social Login über Google                                        | Ja                  |
| Social Login über Facebook                                      | Ja                  |
| Session-Verwaltung mit Refresh-Session                          | Ja                  |
| Logout der aktuellen Session                                    | Ja                  |
| Passwort vergessen / Passwort zurücksetzen                      | Ja                  |
| Passwort ändern                                                 | Ja                  |
| MFA-Recovery                                                    | Ja                  |
| JWT-Ausstellung                                                 | Ja                  |
| JWKS-Bereitstellung                                             | Ja                  |

| Bereich                                              | Muss enthalten sein |
|------------------------------------------------------|---------------------|
| interne Service-Token-Ausstellung                    | Ja                  |
| Idempotency auf kritischen POST-Endpunkten           | Ja                  |
| Cleanup abgelaufener Registrierungen                 | Ja                  |
| Swagger-Dokumentation für Controller, DTOs und Enums | Ja                  |
| positive und negative Tests für alle Funktionen      | Ja                  |

## 2.2 Nicht enthalten

| Bereich                                                            | Muss nicht im auth-service fachlich geführt werden |
|--------------------------------------------------------------------|----------------------------------------------------|
| Rollen- und Berechtigungsverwaltung als Source of Truth            | IAM-Service                                        |
| Benutzerprofil-Verwaltung                                          | User-Service                                       |
| Company-Stammdatenpflege                                           | Company-Service                                    |
| Location-Stammdatenpflege                                          | Company-Service                                    |
| Message-Rendering als eigenständiger Fachbereich                   | externer Service                                   |
| technische Zustellung über Provider als eigenständiger Fachbereich | externer Service                                   |
| JDBC-basierte Persistenz                                           | nicht zulässig                                     |
| MongoDB-basierte Persistenz                                        | nicht zulässig                                     |

## 4. 3. Systemkontext / Abhängigkeiten

### 3.1 Inbound (wer ruft auth-service auf)

| Aufrufer                | Zweck                                                                                    |
|-------------------------|------------------------------------------------------------------------------------------|
| Frontend / Portal       | Registrierung, Social Registrierung, Login, Social Login, MFA, Refresh, Logout, Recovery |
| interne Services        | Anforderung kurzlebiger Service-Tokens                                                   |
| andere Backend-Services | Abruf der öffentlichen Schlüssel über JWKS                                               |
| Monitoring / Betrieb    | Health, Metrics, Actuator                                                                |

### 3.2 Outbound (wen nutzt auth-service)

Der auth-service muss externe Services nur als Abhängigkeiten nutzen. Die Fachlogik dieser Services darf nicht in das Auth-Pflichtenheft übernommen werden.

| Zielservice     | Muss berücksichtigt werden | Zweck im auth-service                                     | Daten, die auth daraus benötigt oder zurückerhalten muss                                     |
|-----------------|----------------------------|-----------------------------------------------------------|----------------------------------------------------------------------------------------------|
| user-service    | Ja                         | Anlegen und Aktivieren des Benutzers                      | userId, companyId, email, firstName, lastName, displayName, status                           |
| company-service | Ja                         | Anlegen und Aktivieren von Company und initialer Location | companyId, companyName, locationId, headquarterLocationId, timezone, countryCode, regionCode |

| Zielservice       | Muss berücksichtigt werden | Zweck im auth-service                                | Daten, die auth daraus benötigt oder zurückerhalten muss                             |
|-------------------|----------------------------|------------------------------------------------------|--------------------------------------------------------------------------------------|
| iam-service       | Ja                         | Initiale Tenant-Admin-Zuordnung und Rechte-Bootstrap | tenantId, subjectId, subjectType, Rollen-/Assignment-Referenzen, Tenant-Admin-Status |
| Messaging-Service | Ja, sofern konfiguriert    | Versand von Verifikations- oder Recovery-Nachrichten | Empfänger, Template-Daten, Zustellstatus                                             |
| Template-Service  | Ja, sofern konfiguriert    | Rendern von Nachrichtentemplates                     | Template-Key, Variablen, Ergebnis                                                    |
| Delivery-Service  | Ja, sofern konfiguriert    | technische Zustellung                                | Provider-Referenz, Zustellstatus, Fehlerstatus                                       |
| Google            | Ja, sofern aktiviert       | Social Registrierung und Social Login                | providerSubject, providerEmail, Provider-Profilinformationen                         |
| Facebook          | Ja, sofern aktiviert       | Social Registrierung und Social Login                | providerSubject, providerEmail, Provider-Profilinformationen                         |

Der auth-service muss auch dann startbar sein, wenn Docker, Downstream-Services oder Social-Provider temporär nicht erreichbar sind. Downstream-Unerreichbarkeit muss als Laufzeitfehler behandelt werden und darf kein Startfehler sein.

### 3.3 Verantwortlichkeiten (Source of Truth)

| Bereich                                                                                  | Führender Service                                             |
|------------------------------------------------------------------------------------------|---------------------------------------------------------------|
| Credentials, Passwort-Hash, MFA, Sessions, Verifikations- und Recovery-Tokens, JWT, JWKS | auth-service                                                  |
| Rollen, Permissions, Module, Assignments, Tenant-Admins                                  | iam-service                                                   |
| Benutzerstammdaten                                                                       | user-service                                                  |
| Company- und Location-Stammdaten                                                         | company-service                                               |
| Zustellung von Nachrichten                                                               | externer Kommunikationsweg                                    |
| externe Social-Identität                                                                 | externer Provider, lokale technische Referenz im auth-service |

## 3.4 Datenflüsse

### 3.4.1 Registrierung / Tenant-Bootstrap

| Schritt | Beschreibung                                                                                       |
|---------|----------------------------------------------------------------------------------------------------|
| 1       | Registrierung muss gestartet werden können.                                                        |
| 2       | Ein PENDING-Registrierungsprozess muss angelegt werden.                                            |
| 3       | Ein PENDING-Benutzer muss im user-service angelegt werden.                                         |
| 4       | Eine PENDING-Company und eine initiale PENDING-Location müssen im company-service angelegt werden. |
| 5       | Der Tenant-Admin-Bootstrap für den ersten Benutzer muss im iam-service vorbereitet werden.         |
| 6       | Ein E-Mail-Bestätigungsprozess muss angestoßen werden.                                             |

| Schritt | Beschreibung                                                                                                                                    |
|---------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| 7       | Eine finale Aktivierung muss erst nach erfolgreicher E-Mail-Verifikation und erfolgreicher 2FA-/MFA-Erfüllung erfolgen, wenn MFA aktiviert ist. |

### 3.4.2 Login / MFA / Session

| Schritt | Beschreibung                                                                                      |
|---------|---------------------------------------------------------------------------------------------------|
| 1       | Der auth-service muss eine primäre Authentifizierung durchführen.                                 |
| 2       | Die primäre Authentifizierung muss Passwort-Login, Google-Login oder Facebook-Login unterstützen. |
| 3       | Danach muss bei aktivierter MFA eine MFA-Prüfung folgen.                                          |
| 4       | Erst nach erfolgreicher MFA muss ein Access Token ausgestellt werden, wenn MFA aktiviert ist.     |
| 5       | Es muss eine Refresh-Session angelegt oder fortgeführt werden.                                    |

### 3.4.3 Recovery / Cleanup / Retry

| Schritt | Beschreibung                                                                           |
|---------|----------------------------------------------------------------------------------------|
| 1       | Passwort-Recovery muss über einen E-Mail-Wiederherstellungsprozess unterstützt werden. |
| 2       | Passwort-Recovery muss optional über SMS unterstützt werden, wenn SMS aktiviert ist.   |
| 3       | MFA-Recovery muss über E-Mail oder SMS unterstützt werden.                             |
| 4       | Tokens müssen serverseitig sicher verwaltet werden.                                    |
| 5       | Abgelaufene PENDING-Registrierungen müssen bereinigt werden.                           |
| 6       | Kritische POST-Endpunkte müssen idempotent verarbeitet werden.                         |
| 7       | Verteilte Teilfehler müssen fachlich behandelt werden.                                 |

## 5. 4. Begriffe

| Begriff          | Bedeutung                                                                   |
|------------------|-----------------------------------------------------------------------------|
| Tenant / Company | Mandant der Plattform                                                       |
| PENDING          | Vorläufiger Zustand vor finaler Aktivierung                                 |
| ACTIVE           | Voll aktivierter Zustand                                                    |
| JWT              | Signierter Access Token                                                     |
| JWKS             | Endpoint mit öffentlichen Signaturschlüsseln                                |
| Refresh-Session  | Serverseitig verwaltete langlebigere Sitzung                                |
| TOTP             | Zeitbasiertes Einmalpasswort aus einer Authenticator-App                    |
| MFA / 2FA        | zusätzlicher Authentifizierungsfaktor nach primärer Anmeldung               |
| Service-Token    | Kurzlebiger JWT für interne Service-Aufrufe                                 |
| Idempotency-Key  | Schlüssel für wiederholbare POST-Operationen                                |
| tenant_id        | Technischer Mandantenbezug im JWT                                           |
| subject_type     | Kennzeichnung, ob das Token einen Benutzer oder einen Service repräsentiert |
| Social Identity  | technische Verknüpfung eines lokalen Auth-Accounts mit Google oder Facebook |

## 6. 5. IAM-Absicherung und Mandantentrennung

### 5.1 Grundprinzip

Der auth-service muss JWTs ausstellen.

Der auth-service muss interne geschützte Endpunkte mit Bearer JWT absichern.

Der auth-service muss für geschützte Endpunkte das Default-Deny-Prinzip umsetzen.

Der auth-service muss den Mandantenkontext sauber trennen.

Der auth-service muss eine konfigurierbare 2FA-/MFA-Funktion unterstützen.

Der auth-service muss bei aktivierter 2FA einen zweiten Faktor erzwingen.

### 5.2 JWT-Contract

Der JWT-Token des auth-service muss mit dem in IAM definierten JWT-Token übereinstimmen.

| Claim        | Muss vorhanden sein |
|--------------|---------------------|
| iss          | Ja                  |
| sub          | Ja                  |
| aud          | Ja                  |
| iat          | Ja                  |
| exp          | Ja                  |
| jti          | Ja                  |
| tenant_id    | Ja                  |
| subject_type | Ja                  |
| scp          | Ja                  |

| Regel        | Muss gelten                               |
|--------------|-------------------------------------------|
| aud          | Muss als Array ausgegeben werden          |
| scp          | Muss als Array ausgegeben werden          |
| subject_type | Muss USER oder SERVICE sein               |
| sid          | Muss für Session-Bezug unterstützt werden |
| amr          | Muss bei MFA verwendet werden können      |
| auth_time    | Muss unterstützt werden                   |

### 5.3 Tenant-Kontext und Konsistenzprüfungen

| Regel              | Muss gelten                                                     |
|--------------------|-----------------------------------------------------------------|
| tenant_id im JWT   | Muss Quelle der Wahrheit sein                                   |
| X-Tenant-Id Header | Muss verarbeitet werden können                                  |
| Konsistenzprüfung  | Header und Claim müssen übereinstimmen, wenn beide gesetzt sind |
| Abweichung         | Request muss abgelehnt werden                                   |

### 5.4 Autorisierung über Rollen-/Admin-Logik

| Bereich               | Route                                  | Absicherung             |
|-----------------------|----------------------------------------|-------------------------|
| Registrierung starten | POST /api/v1/registration/start        | öffentlich              |
| E-Mail verifizieren   | POST /api/v1/registration/verify-email | Token-basierter Kontext |

| Bereich                       | Route                                         | Absicherung                   |
|-------------------------------|-----------------------------------------------|-------------------------------|
| MFA Enrollment starten        | POST<br>/api/v1/registration/mfa/totp/enroll  | PENDING-Registrierungskontext |
| MFA Enrollment bestätigen     | POST<br>/api/v1/registration/mfa/totp/confirm | PENDING-Registrierungskontext |
| Social Registrierung Google   | POST<br>/api/v1/registration/social/google    | öffentlich                    |
| Social Registrierung Facebook | POST<br>/api/v1/registration/social/facebook  | öffentlich                    |
| Login                         | POST /api/v1/auth/login                       | öffentlich                    |
| Social Login Google           | POST /api/v1/auth/social/google               | öffentlich                    |
| Social Login Facebook         | POST<br>/api/v1/auth/social/facebook          | öffentlich                    |
| MFA Verify                    | POST /api/v1/auth/mfa/verify                  | Challenge-Kontext             |
| Refresh                       | POST /api/v1/auth/refresh                     | gültige Refresh-Session       |
| Logout                        | POST /api/v1/auth/logout                      | gültige Session               |
| Passwort vergessen            | POST /api/v1/password/forgot                  | öffentlich                    |
| Passwort zurücksetzen         | POST /api/v1/password/reset                   | Reset-Token                   |
| Passwort ändern               | POST /api/v1/password/change                  | authentifiziert               |
| MFA Recovery Start            | POST /api/v1/mfa/recovery/start               | öffentlich                    |
| MFA Recovery Confirm          | POST<br>/api/v1/mfa/recovery/confirm          | Recovery-Token                |
| Service-Token ausstellen      | POST<br>/api/v1/internal/tokens/service       | intern authentifiziert        |
| JWKS                          | GET /.well-known/jwks.json                    | öffentlich                    |

## 7. 6. REST-API – Übersicht

### 6.1 Basis-URL, Versionierung, Content Types

| Feld                  | Vorgabe          |
|-----------------------|------------------|
| API Context Path      | /api/v1          |
| Request Content-Type  | application/json |
| Response Content-Type | application/json |
| Fehlerformat          | application/json |
| Versionsstrategie     | v1 im Pfad       |

Der auth-service muss folgende Header unterstützen:

| Header           | Regel                                                   |
|------------------|---------------------------------------------------------|
| X-Correlation-Id | Muss übernommen oder erzeugt werden                     |
| Idempotency-Key  | Muss auf definierten POST-Endpunkten verpflichtend sein |
| X-Tenant-Id      | Muss unterstützt werden                                 |

Der auth-service muss alle Controller, DTOs und Enums ausführlich per Swagger dokumentieren.

| Bereich       | Muss dokumentiert werden |
|---------------|--------------------------|
| Controller    | Ja                       |
| Request-DTOs  | Ja                       |
| Response-DTOs | Ja                       |
| Enums         | Ja                       |

| Bereich         | Muss dokumentiert werden |
|-----------------|--------------------------|
| Header          | Ja                       |
| Query-Parameter | Ja                       |
| Path-Parameter  | Ja                       |
| Fehlerfälle     | Ja                       |
| Beispiele       | Ja                       |

## 6.2 Endpunkte

| Bereich              | Route                                      |
|----------------------|--------------------------------------------|
| Registrierung        | POST /api/v1/registration/start            |
| Registrierung        | POST /api/v1/registration/verify-email     |
| Registrierung        | POST /api/v1/registration/mfa/totp/enroll  |
| Registrierung        | POST /api/v1/registration/mfa/totp/confirm |
| Social Registrierung | POST /api/v1/registration/social/google    |
| Social Registrierung | POST /api/v1/registration/social/facebook  |
| Auth / Session       | POST /api/v1/auth/login                    |
| Auth / Session       | POST /api/v1/auth/mfa/verify               |
| Auth / Session       | POST /api/v1/auth/refresh                  |
| Auth / Session       | POST /api/v1/auth/logout                   |
| Social Login         | POST /api/v1/auth/social/google            |
| Social Login         | POST /api/v1/auth/social/facebook          |
| Passwort             | POST /api/v1/password/forgot               |
| Passwort             | POST /api/v1/password/reset                |
| Passwort             | POST /api/v1/password/change               |
| MFA Recovery         | POST /api/v1/mfa/recovery/start            |
| MFA Recovery         | POST /api/v1/mfa/recovery/confirm          |
| interne Tokens       | POST /api/v1/internal/tokens/service       |
| Key Discovery        | GET /.well-known/jwks.json                 |

## 6.3 Standard-Query

Der auth-service muss für die öffentlichen Auth-Endpunkte kein generisches Paging benötigen.

Wenn interne Listen ergänzt werden, muss der Service folgende Standard-Parameter unterstützen:

| Parameter | Bedeutung    |
|-----------|--------------|
| page      | Seitennummer |
| size      | Seitengröße  |
| sort      | Sortierung   |

# 8. 7. Funktionale Anforderungen

## 7.1 Registrierung starten

| Anforderung                                | Muss gelten |
|--------------------------------------------|-------------|
| PENDING-Registrierung anlegen              | Ja          |
| PENDING-Benutzer anlegen                   | Ja          |
| PENDING-Company anlegen                    | Ja          |
| PENDING-Location anlegen                   | Ja          |
| initialen Tenant-Admin-Kontext vorbereiten | Ja          |
| Verifikationsprozess auslösen              | Ja          |
| E-Mail-Bestätigungsprozess anstoßen        | Ja          |
| Idempotency-Key verlangen                  | Ja          |

| Anforderung                                                  | Muss gelten |
|--------------------------------------------------------------|-------------|
| Registrierungsablauf innerhalb der Gültigkeitszeit absichern | Ja          |

## 7.2 E-Mail verifizieren

| Anforderung                               | Muss gelten |
|-------------------------------------------|-------------|
| kurzlebigen Verifikationstoken verwenden  | Ja          |
| Token nur gehasht speichern               | Ja          |
| One-Time-Use erzwingen                    | Ja          |
| Ablauf prüfen                             | Ja          |
| erneute Anforderung kontrolliert zulassen | Ja          |

## 7.3 MFA Enrollment starten / bestätigen

| Anforderung                                                          | Muss gelten |
|----------------------------------------------------------------------|-------------|
| MFA als konfigurierbare Sicherheitsfunktion unterstützen             | Ja          |
| MFA bei aktivierter Konfiguration erzwingen                          | Ja          |
| TOTP als zweiten Faktor unterstützen                                 | Ja          |
| TOTP-Enrollment nach erfolgreicher Registrierung zulassen            | Ja          |
| Enrollment-Daten für Authenticator-App bereitstellen                 | Ja          |
| Bestätigung durch TOTP-Code prüfen                                   | Ja          |
| Aktivierung ohne erfolgreiche MFA verhindern, wenn MFA aktiviert ist | Ja          |

## 7.4 Aktivierung User / Company / IAM

| Anforderung                                                                | Muss gelten |
|----------------------------------------------------------------------------|-------------|
| Aktivierung erst nach E-Mail-Verifikation durchführen                      | Ja          |
| Aktivierung erst nach TOTP-Bestätigung durchführen, wenn MFA aktiviert ist | Ja          |
| Benutzer im user-service aktivieren                                        | Ja          |
| Company im company-service aktivieren                                      | Ja          |
| Location im company-service aktivieren                                     | Ja          |
| initiale Tenant-Admin-Zuordnung im iam-service durchführen                 | Ja          |
| technische Konsistenz zwischen den Services herstellen                     | Ja          |

## 7.5 Login / MFA Verify

| Anforderung                                                   | Muss gelten |
|---------------------------------------------------------------|-------------|
| Passwort-Login unterstützen                                   | Ja          |
| Social Login über Google unterstützen                         | Ja          |
| Social Login über Facebook unterstützen                       | Ja          |
| Social Registrierung über Google unterstützen                 | Ja          |
| Social Registrierung über Facebook unterstützen               | Ja          |
| Login zweistufig durchführen, wenn MFA aktiviert ist          | Ja          |
| nach primärer Anmeldung MFA verlangen, wenn MFA aktiviert ist | Ja          |
| TOTP als regulären zweiten Faktor unterstützen                | Ja          |

| Anforderung                                                                       | Muss gelten |
|-----------------------------------------------------------------------------------|-------------|
| erst nach erfolgreicher MFA einen Access Token ausstellen, wenn MFA aktiviert ist | Ja          |
| Session-Policy 24 Stunden unterstützen                                            | Ja          |
| Session-Policy 3 Monate unterstützen                                              | Ja          |

## 7.6 Refresh Session

| Anforderung                                              | Muss gelten |
|----------------------------------------------------------|-------------|
| Refresh nur über gültige Refresh-Session zulassen        | Ja          |
| kurzlebige Access Tokens ausstellen                      | Ja          |
| Refresh-Missbrauch erkennen                              | Ja          |
| Statusänderungen spätestens beim Refresh berücksichtigen | Ja          |

## 7.7 Logout

| Anforderung                                         | Muss gelten |
|-----------------------------------------------------|-------------|
| die aktuelle Refresh-Session widerrufen             | Ja          |
| den aktuellen Access Token regulär auslaufen lassen | Ja          |
| die Session technisch sauber beenden                | Ja          |

## 7.8 Passwort vergessen / Passwort zurücksetzen / Passwort ändern

| Anforderung                                                                                 | Muss gelten |
|---------------------------------------------------------------------------------------------|-------------|
| bei „Passwort vergessen“ neutral antworten                                                  | Ja          |
| einen E-Mail-Wiederherstellungsprozess anstoßen                                             | Ja          |
| optional einen SMS-basierten Wiederherstellungsprozess unterstützen, wenn SMS aktiviert ist | Ja          |
| kurzlebige Reset-Tokens verwenden                                                           | Ja          |
| Reset-Tokens nur einmal verwendbar machen                                                   | Ja          |
| Reset-Tokens sicher speichern                                                               | Ja          |
| nach Passwort-Reset Sessions widerrufen                                                     | Ja          |
| Passwortänderung nur authentifiziert zulassen                                               | Ja          |

## 7.9 MFA Recovery

| Anforderung                                                        | Muss gelten |
|--------------------------------------------------------------------|-------------|
| MFA-Recovery getrennt vom normalen Login behandeln                 | Ja          |
| Recovery per E-Mail unterstützen                                   | Ja          |
| Recovery per SMS unterstützen                                      | Ja          |
| Recovery-Kanal per Konfiguration steuerbar machen                  | Ja          |
| Recovery-Token kurzlebig verwalten                                 | Ja          |
| alte MFA-Konfiguration nach erfolgreicher Recovery ungültig machen | Ja          |
| neues Enrollment erzwingen                                         | Ja          |
| Sessions widerrufen                                                | Ja          |

## 7.10 Service-Token ausstellen

| Anforderung                                        | Muss gelten |
|----------------------------------------------------|-------------|
| internen Endpoint für Service-Tokens bereitstellen | Ja          |
| Audience entgegennehmen                            | Ja          |
| Tenant-Bezug entgegennehmen                        | Ja          |

| Anforderung                          | Muss gelten |
|--------------------------------------|-------------|
| Scope-Satz entgegennehmen            | Ja          |
| TTL entgegennehmen                   | Ja          |
| kurzlebige Service-Tokens ausstellen | Ja          |
| Least-Privilege umsetzen             | Ja          |

### 7.11 Beziehungen / Referenzmodell

| Bezug           | Beschreibung                                                                                      |
|-----------------|---------------------------------------------------------------------------------------------------|
| User            | Der auth-service muss Benutzer über userId referenzieren.                                         |
| Company         | Der auth-service muss Mandanten über companyId bzw. tenant_id referenzieren.                      |
| IAM             | Der auth-service muss IAM für Tenant-Admin-Bootstrap und Rechtekonsistenz anbinden.               |
| Session         | Der auth-service muss Sessions lokal über sid und Refresh-Session-Daten verwalten.                |
| JWT             | Der auth-service muss JTI, SID, Claims und Signatur zentral führen.                               |
| Social Identity | Der auth-service muss Google- und Facebook-Identitäten technisch einem lokalen Benutzer zuordnen. |

## 9. 8. Datenmodell

### 8.1 AuthCredential

| Feld           |
|----------------|
| id             |
| userId         |
| loginEmail     |
| passwordHash   |
| status         |
| emailVerified  |
| failedAttempts |
| lockedUntil    |
| lastLoginAt    |
| createdAt      |
| modifiedAt     |

### 8.2 AuthIdentity

| Feld            |
|-----------------|
| id              |
| credentialId    |
| provider        |
| providerSubject |
| providerEmail   |
| createdAt       |

Zusätzlich muss gelten:

| Feld     | Muss gelten                                             |
|----------|---------------------------------------------------------|
| provider | Muss mindestens LOCAL, GOOGLE und FACEBOOK unterstützen |

| Feld            | Muss gelten                                              |
|-----------------|----------------------------------------------------------|
| providerSubject | Muss die externe Provider-Identität eindeutig speichern  |
| providerEmail   | Muss die vom Provider gelieferte E-Mail speichern können |

### 8.3 RegistrationProcess

| Feld            |
|-----------------|
| registrationId  |
| tenantId        |
| userId          |
| status          |
| companyPayload  |
| locationPayload |
| userPayload     |
| expiresAt       |
| createdAt       |
| modifiedAt      |

### 8.4 MfaConfig

| Feld                |
|---------------------|
| id                  |
| credentialId        |
| enabled             |
| secondFactorType    |
| emailChannelEnabled |
| smsChannelEnabled   |
| totpSecretEncrypted |
| enrolledAt          |
| createdAt           |
| modifiedAt          |

Zusätzlich muss gelten:

| Feld                | Muss gelten                       |
|---------------------|-----------------------------------|
| enabled             | Muss steuern, ob MFA aktiv ist    |
| secondFactorType    | Muss mindestens TOTP unterstützen |
| emailChannelEnabled | Muss konfigurierbar sein          |
| smsChannelEnabled   | Muss konfigurierbar sein          |

### 8.5 RefreshSession

| Feld             |
|------------------|
| sid              |
| credentialId     |
| userId           |
| tenantId         |
| sessionPolicy    |
| refreshTokenHash |
| ipAddress        |
| userAgent        |
| expiresAt        |
| revokedAt        |
| lastUsedAt       |

| Feld       |
|------------|
| createdAt  |
| modifiedAt |

## 8.6 VerificationToken

| Feld         |
|--------------|
| id           |
| credentialId |
| tokenHash    |
| expiresAt    |
| usedAt       |
| createdAt    |

## 8.7 PasswordResetToken

| Feld         |
|--------------|
| id           |
| credentialId |
| tokenHash    |
| expiresAt    |
| usedAt       |
| createdAt    |

## 8.8 MfaRecoveryToken

| Feld         |
|--------------|
| id           |
| credentialId |
| tokenHash    |
| expiresAt    |
| consumedAt   |
| createdAt    |

## 8.9 IdempotencyRecord

| Feld           |
|----------------|
| id             |
| idempotencyKey |
| requestHash    |
| responseStatus |
| responseBody   |
| createdAt      |
| expiresAt      |

## 8.10 JwtKeyMetadata

| Feld          |
|---------------|
| kid           |
| algorithm     |
| publicKey     |
| privateKeyRef |
| status        |
| createdAt     |
| validFrom     |
| validUntil    |

## 8.11 Persistenz- und Migrationsregeln

| Regel                     | Muss gelten                 |
|---------------------------|-----------------------------|
| produktive Datenbank      | nur MySQL oder MariaDB      |
| ORM / Persistenz          | nur JPA / Hibernate         |
| JDBC                      | darf nicht verwendet werden |
| MongoDB                   | darf nicht verwendet werden |
| Migrationen               | müssen versioniert sein     |
| Flyway                    | muss verwendet werden       |
| Schema-Handling produktiv | muss validierend sein       |

## 10.9. Idempotency-Regeln

Der auth-service muss auf folgenden Endpunkten einen Idempotency-Key verlangen:

| Endpunkt                                   |
|--------------------------------------------|
| POST /api/v1/registration/start            |
| POST /api/v1/registration/verify-email     |
| POST /api/v1/registration/mfa/totp/confirm |
| POST /api/v1/registration/social/google    |
| POST /api/v1/registration/social/facebook  |
| POST /api/v1/auth/login                    |
| POST /api/v1/auth/social/google            |
| POST /api/v1/auth/social/facebook          |
| POST /api/v1/auth/mfa/verify               |
| POST /api/v1/password/forgot               |
| POST /api/v1/password/reset                |
| POST /api/v1/mfa/recovery/start            |
| POST /api/v1/mfa/recovery/confirm          |
| POST /api/v1/internal/tokens/service       |

| Regel                          | Muss gelten                         |
|--------------------------------|-------------------------------------|
| gleicher Key + gleiche Payload | muss gleiche Antwort liefern        |
| gleicher Key + andere Payload  | muss Konflikt auslösen              |
| Aufbewahrung                   | muss mindestens 24 Stunden betragen |

## 11.10. Fehlerformat, Statuscodes, Fehlercodes

### 10.1 Fehlerformat

Fehlerantworten müssen JSON sein und folgende Felder enthalten:

| Feld          |
|---------------|
| timestamp     |
| status        |
| errorCode     |
| message       |
| correlationId |
| path          |
| details       |

## 10.2 Fehlercode-Mapping

| Fehlernummer | code                                 | message                              | Erscheint, wenn ...                                            |
|--------------|--------------------------------------|--------------------------------------|----------------------------------------------------------------|
| 400          | VALIDATION_ERROR                     | Request validation failed            | Request verletzt Validierung                                   |
| 401          | INVALID_CREDENTIALS                  | Invalid credentials                  | Benutzername oder Passwort falsch                              |
| 401          | TOKEN_INVALID                        | Token invalid                        | Token ist ungültig                                             |
| 401          | TOKEN_EXPIRED                        | Token expired                        | Token ist abgelaufen                                           |
| 401          | TOTP_INVALID                         | Invalid TOTP code                    | TOTP-Code ist falsch                                           |
| 401          | SOCIAL_AUTH_FAILED                   | Social authentication failed         | Google- oder Facebook-Authentifizierung fehlgeschlagen ist     |
| 403          | EMAIL_NOT_VERIFIED                   | Email not verified                   | E-Mail-Verifikation fehlt                                      |
| 403          | MFA_NOT_ENROLLED                     | MFA not enrolled                     | MFA wurde noch nicht eingerichtet                              |
| 403          | MFA_REQUIRED                         | MFA required                         | MFA aktiviert ist und noch nicht erfolgreich erfüllt wurde     |
| 403          | TENANT_MISMATCH                      | Tenant mismatch                      | Tenant-Angabe stimmt nicht mit tenant_id überein               |
| 409          | IDEMPOTENCY_CONFLICT                 | Idempotency conflict                 | gleicher Key mit anderer Payload                               |
| 409          | DUPLICATE_EMAIL                      | Email already exists                 | E-Mail ist bereits vergeben                                    |
| 409          | SOCIAL_IDENTITY_ALREADY_LINKED       | Social identity already linked       | Social-Identität bereits einem anderen Benutzer zugeordnet ist |
| 409          | EMAIL_ALREADY_USED_BY_OTHER_PROVIDER | Email already used by other provider | dieselbe E-Mail bereits mit anderer Login-Art verwendet wird   |
| 404          | REGISTRATION_NOT_FOUND               | Registration not found               | Registrierung existiert nicht                                  |
| 410          | REGISTRATION_EXPIRED                 | Registration expired                 | Registrierung ist abgelaufen                                   |
| 503          | DOWNSTREAM_USER_UNAVAILABLE          | User service unavailable             | user-service nicht erreichbar                                  |
| 503          | DOWNSTREAM_COMPANY_UNAVAILABLE       | Company service unavailable          | company-service nicht erreichbar                               |
| 503          | DOWNSTREAM_IAM_UNAVAILABLE           | IAM service unavailable              | iam-service nicht erreichbar                                   |
| 503          | SOCIAL_PROVIDER_UNAVAILABLE          | Social provider unavailable          | Google oder Facebook nicht erreichbar ist                      |
| 403          | SCOPE_MISSING                        | Required scope missing               | Scope fehlt                                                    |
| 403          | ACCESS_DENIED                        | Access denied                        | Zugriff abgelehnt                                              |
| 429          | RATE_LIMITED                         | Too many requests                    | Rate-Limit überschritten                                       |

## 12.11. Betrieb / Deployment / Konfiguration

### 11.1 Serviceeigene Ports

#### 11.1.1 API/Application Port

| Variable         | Default |
|------------------|---------|
| AUTH_SERVER_PORT | 8101    |

#### 11.1.2 Management/Actuator Port

| Variable                    | Default |
|-----------------------------|---------|
| AUTH_MANAGEMENT_SERVER_PORT | 8201    |

#### 11.1.3 Optionale Ports

Der auth-service muss keine weiteren Pflichtports besitzen.

#### 11.1.4 Regel bei parallelem Betrieb mehrerer Services auf einem Host

| Regel                           | Muss gelten                                                     |
|---------------------------------|-----------------------------------------------------------------|
| API-Port                        | muss ausschließlich über Umgebungsvariablen konfigurierbar sein |
| Management-Port                 | muss ausschließlich über Umgebungsvariablen konfigurierbar sein |
| Trennung API / Management       | muss vorhanden sein                                             |
| hart kodierte Portwerte         | dürfen nicht erforderlich sein                                  |
| interne statische Konfiguration | darf nicht die einzige Konfigurationsquelle sein                |

### 11.2 Pfad-Konfiguration

| Bereich            | Vorgabe                                    |
|--------------------|--------------------------------------------|
| API Context Path   | muss über Umgebungsvariable gesetzt werden |
| JWKS Path          | muss über Umgebungsvariable gesetzt werden |
| Swagger UI Path    | muss über Umgebungsvariable gesetzt werden |
| API Docs Path      | muss über Umgebungsvariable gesetzt werden |
| Actuator Base Path | muss über Umgebungsvariable gesetzt werden |

### 11.3 JWT-Konfiguration

Der auth-service muss sämtliche JWT-bezogenen Einstellungen ausschließlich über Umgebungsvariablen von außen konfigurierbar machen.

| Bereich                | Muss über Umgebungsvariable konfigurierbar sein |
|------------------------|-------------------------------------------------|
| Issuer                 | Ja                                              |
| Key-ID                 | Ja                                              |
| Signaturalgorithmus    | Ja                                              |
| Access-Token-TTL       | Ja                                              |
| Refresh-Session-TTL    | Ja                                              |
| Audience-Prüfung       | Ja                                              |
| Clock-Skew             | Ja                                              |
| erlaubte Subject Types | Ja                                              |

### 11.4 Umgebungsvariablen

Der auth-service muss sämtliche fachlichen, technischen und betrieblichen Konfigurationen ausschließlich über von außen gesetzte Umgebungsvariablen beziehen.

| Variable                       | Zweck                                               |
|--------------------------------|-----------------------------------------------------|
| AUTH_SERVER_PORT               | API-Port                                            |
| AUTH_MANAGEMENT_SERVER_PORT    | Management-Port                                     |
| AUTH_CONTEXT_PATH              | API Context Path                                    |
| AUTH_JWKS_PATH                 | JWKS-Pfad                                           |
| AUTH_SWAGGER_UI_PATH           | Swagger-UI-Pfad                                     |
| AUTH_API_DOCS_PATH             | OpenAPI-Docs-Pfad                                   |
| AUTH_ACTUATOR_BASE_PATH        | Actuator-Basispfad                                  |
| AUTH_DB_HOST                   | Datenbank-Host                                      |
| AUTH_DB_PORT                   | Datenbank-Port                                      |
| AUTH_DB_NAME                   | Datenbankname                                       |
| AUTH_DB_USER                   | Datenbankbenutzer                                   |
| AUTH_DB_PASSWORD               | Datenbankpasswort                                   |
| AUTH_DB_SCHEMA                 | Datenbankschema                                     |
| AUTH_ISSUER                    | JWT-Issuer                                          |
| AUTH_JWKS_KEY_ID               | Key-ID                                              |
| AUTH_JWT_ALGORITHM             | JWT-Algorithmus                                     |
| AUTH_JWT_ACCESS_TOKEN_TTL      | TTL Access Token                                    |
| AUTH_REFRESH_HOURS_24_TTL      | TTL 24h-Session                                     |
| AUTH_REFRESH_MONTHS_3_TTL      | TTL 3-Monats-Session                                |
| AUTH_VERIFICATION_TOKEN_TTL    | TTL Verifikation                                    |
| AUTH_PASSWORD_RESET_TTL        | TTL Passwort-Reset                                  |
| AUTH_MFA_RECOVERY_TTL          | TTL MFA-Recovery                                    |
| AUTH_IDEMPOTENCY_TTL           | TTL Idempotency                                     |
| AUTH_MFA_ENABLED               | aktiviert oder deaktiviert MFA                      |
| AUTH_MFA_SECOND_FACTOR         | definiert den zweiten Faktor                        |
| AUTH_EMAIL_CHANNEL_ENABLED     | aktiviert E-Mail-Kanal                              |
| AUTH_SMS_CHANNEL_ENABLED       | aktiviert SMS-Kanal                                 |
| AUTH_GOOGLE_LOGIN_ENABLED      | aktiviert Google-Login und Google-Registrierung     |
| AUTH_FACEBOOK_LOGIN_ENABLED    | aktiviert Facebook-Login und Facebook-Registrierung |
| AUTH_GOOGLE_CLIENT_ID          | OAuth-Client-ID Google                              |
| AUTH_GOOGLE_CLIENT_SECRET      | OAuth-Client-Secret Google                          |
| AUTH_FACEBOOK_CLIENT_ID        | OAuth-Client-ID Facebook                            |
| AUTH_FACEBOOK_CLIENT_SECRET    | OAuth-Client-Secret Facebook                        |
| AUTH_USER_SERVICE_BASE_URL     | URL user-service                                    |
| AUTH_COMPANY_SERVICE_BASE_URL  | URL company-service                                 |
| AUTH_IAM_SERVICE_BASE_URL      | URL iam-service                                     |
| AUTH_MESSAGE_SERVICE_BASE_URL  | URL Messaging-Service                               |
| AUTH_TEMPLATE_SERVICE_BASE_URL | URL Template-Service                                |
| AUTH_DELIVERY_SERVICE_BASE_URL | URL Delivery-Service                                |
| AUTH_RATE_LIMIT_LOGIN          | Rate-Limit Login                                    |
| AUTH_RATE_LIMIT_REGISTRATION   | Rate-Limit Registrierung                            |
| AUTH_RATE_LIMIT_PASSWORD_RESET | Rate-Limit Passwort-Reset                           |
| AUTH_RATE_LIMIT_MFA_RECOVERY   | Rate-Limit MFA-Recovery                             |

## 11.5 Logging, Audit und Nachvollziehbarkeit

Der auth-service muss strukturiertes, sicherheitskonformes und nachvollziehbares Logging verwenden.

Der auth-service muss alle fachlich und technisch relevanten Vorgänge mit Logging und CorrelationId unterstützen.

Der auth-service muss Logging so umsetzen, dass keine sensiblen Werte protokolliert werden.

Der auth-service muss Logging so umsetzen, dass ein Ausfall eines zentralen Logging-Ziels die fachliche Verarbeitung nicht blockiert.

Der auth-service muss sicherheits- und supportrelevante Ereignisse zusätzlich auditierbar machen.

### 11.5.1 Pflichtinhalte des Logging

| Bereich                         | Muss gelten                                      |
|---------------------------------|--------------------------------------------------|
| Logging-Format                  | Muss strukturiert erfolgen                       |
| CorrelationId                   | Muss in allen relevanten Logs enthalten sein     |
| Log-Level                       | Müssen konsistent verwendet werden               |
| Fehlerfälle                     | Müssen mit Fehlercode und Kontext geloggt werden |
| externe Service-Aufrufe         | Müssen vor und nach dem Aufruf geloggt werden    |
| sicherheitsrelevante Ereignisse | Müssen gesondert nachvollziehbar sein            |
| sensitive Daten                 | Dürfen nicht im Klartext geloggt werden          |

### 11.5.2 Ereignisse, die protokolliert werden müssen

| Ereignis                                                    | Muss geloggt werden |
|-------------------------------------------------------------|---------------------|
| Registrierung gestartet                                     | Ja                  |
| Registrierung bestätigt                                     | Ja                  |
| Registrierung abgelaufen                                    | Ja                  |
| Social Registrierung Google/Facebook                        | Ja                  |
| Login erfolgreich                                           | Ja                  |
| Login fehlgeschlagen                                        | Ja                  |
| Social Login erfolgreich/fehlgeschlagen                     | Ja                  |
| MFA erforderlich                                            | Ja                  |
| MFA erfolgreich/fehlgeschlagen                              | Ja                  |
| E-Mail-Verifikation<br>gestartet/erfolgreich/fehlgeschlagen | Ja                  |
| Passwort-Reset<br>angefordert/erfolgreich/fehlgeschlagen    | Ja                  |
| MFA-Recovery<br>angefordert/erfolgreich/fehlgeschlagen      | Ja                  |
| Refresh erfolgreich/fehlgeschlagen                          | Ja                  |
| Logout erfolgreich/fehlgeschlagen                           | Ja                  |
| Service-Token ausgestellt/abgelehnt                         | Ja                  |
| Downstream-Aufruf an user/company/iam                       | Ja                  |
| Retry / Kompensation / Teilfehler                           | Ja                  |
| Rate-Limit / Abuse-Schutz ausgelöst                         | Ja                  |
| Tenant-Mismatch / Access Denied                             | Ja                  |

### 11.5.3 Mindestfelder je Logeintrag

| Feld          | Muss enthalten sein |
|---------------|---------------------|
| timestamp     | Ja                  |
| level         | Ja                  |
| service       | Ja                  |
| eventName     | Ja                  |
| correlationId | Ja                  |
| tenantId      | sofern vorhanden    |
| userId        | sofern vorhanden    |
| sid           | sofern vorhanden    |
| requestPath   | sofern HTTP-bezogen |
| httpMethod    | sofern HTTP-bezogen |
| httpStatus    | sofern vorhanden    |
| durationMs    | sofern messbar      |
| outcome       | Ja                  |
| errorCode     | bei Fehlern         |
| targetService | bei externen Calls  |

#### 11.5.4 Verbotene Inhalte in Logs

| Inhalt                                      | Darf nicht geloggt werden |
|---------------------------------------------|---------------------------|
| Passwörter                                  | Ja                        |
| vollständige JWTs                           | Ja                        |
| Refresh-Tokens                              | Ja                        |
| Reset-Tokens                                | Ja                        |
| Verifikationstokens                         | Ja                        |
| TOTP-Secrets                                | Ja                        |
| OAuth-Client-Secrets                        | Ja                        |
| Authorization-Header vollständig            | Ja                        |
| unmaskierte sensible personenbezogene Daten | Ja                        |

#### 11.5.5 Audit-Logging

Der auth-service muss für sicherheits- und supportrelevante Ereignisse ein getrennt auswertbares Audit-Logging bereitstellen. Audit-relevant sind insbesondere Login, fehlgeschlagene Logins, MFA-Änderungen, Passwortänderungen, Passwort-Reset, Recovery, Session-Widerruf, Token-Ausstellung und supportrelevante Diagnosezugriffe.

#### 11.6 Support-Diagnosezugriffe und Tenant-bezogene Auswertung

Der auth-service muss supportseitige Diagnosezugriffe für autorisierte Portalmitarbeiter unterstützen.

Der auth-service muss Support-Diagnosezugriffe strikt von regulären Fachzugriffen trennen.

Der auth-service muss bei Support-Diagnosezugriffen das Prinzip der Datenminimierung einhalten.

Der auth-service muss standardmäßig nur technische und betriebliche Diagnoseinformationen bereitstellen.

Der auth-service darf bei Support-Diagnosezugriffen keine unnötigen fachlichen oder personenbezogenen Detaildaten offenlegen.

##### 11.6.1 Pflichtregeln

| Bereich              | Muss gelten                                                                        |
|----------------------|------------------------------------------------------------------------------------|
| Support-Rolle        | Muss getrennt von regulären Tenant-Rollen geführt werden                           |
| Zugriffszweck        | Muss auf Diagnose und Fehleranalyse beschränkt sein                                |
| Tenant-Bezug         | Muss über tenantId, companyId oder einen definierten Tenant-Schlüssel möglich sein |
| Datenminimierung     | Muss standardmäßig angewendet werden                                               |
| Personenbezug        | Muss vermieden oder maskiert werden, sofern nicht zwingend erforderlich            |
| Fachdatenzugriff     | Darf nicht automatisch aus dem Support-Zugriff folgen                              |
| Break-Glass-Zugriff  | Muss gesondert steuerbar und auditierbar sein, sofern vorhanden                    |
| Auditierung          | Jeder Support-Diagnosezugriff muss vollständig protokolliert werden                |
| Berechtigungsprüfung | Muss vor jeder Diagnoseabfrage erfolgen                                            |
| Ergebnisumfang       | Muss auf technische Diagnoseinformationen beschränkt sein                          |

##### 11.6.2 Zulässige Diagnoseinformationen

| Information                 | Darf bereitgestellt werden |
|-----------------------------|----------------------------|
| Tenant- oder Company-Status | Ja                         |
| Status technischer Prozesse | Ja                         |

| Information                              | Darf bereitgestellt werden |
|------------------------------------------|----------------------------|
| letzter bekannter Fehlercode             | Ja                         |
| letzter Fehlerzeitpunkt                  | Ja                         |
| beteiligter Service                      | Ja                         |
| CorrelationId                            | Ja                         |
| Retry-Status                             | Ja                         |
| Kommunikationsstatus                     | Ja                         |
| Zustellstatus                            | Ja                         |
| Aktivierungsstatus                       | Ja                         |
| Konfigurationsstatus relevanter Schalter | Ja                         |
| technische Warnungen                     | Ja                         |

### 11.6.3 Standardmäßig nicht anzuzeigende Informationen

| Information                               | Darf nicht standardmäßig angezeigt werden |
|-------------------------------------------|-------------------------------------------|
| Passwörter                                | Ja                                        |
| Tokens                                    | Ja                                        |
| Secrets                                   | Ja                                        |
| vollständige personenbezogene Inhalte     | Ja                                        |
| vollständige Payloads fachlicher Requests | Ja                                        |
| vollständige Kommunikationsinhalte        | Ja                                        |
| vollständige E-Mail-Texte                 | Ja                                        |
| vollständige Telefonnummern               | Ja                                        |
| unmaskierte Identitätsdaten               | Ja                                        |

### 11.6.4 Audit-Logging für Supportzugriffe

Der auth-service muss jeden Support-Diagnosezugriff als Audit-Ereignis protokollieren.

| Feld                             | Muss enthalten sein |
|----------------------------------|---------------------|
| timestamp                        | Ja                  |
| supportUserId                    | Ja                  |
| supportRole                      | Ja                  |
| tenantId / companyId / tenantKey | Ja                  |
| Aktion                           | Ja                  |
| Diagnosezweck                    | Ja                  |
| Ergebnisstatus                   | Ja                  |
| correlationId                    | Ja                  |
| errorCode                        | bei Fehlern         |
| Break-Glass-Kennzeichen          | sofern verwendet    |

## 11.7 Datenschutz, DSGVO, Lösch- und Aufbewahrungsregeln

Der auth-service muss datenschutzkonform und nach dem Prinzip der Datenminimierung umgesetzt werden.

Der auth-service muss personenbezogene Daten nur verarbeiten, soweit dies für den jeweiligen fachlichen oder technischen Zweck erforderlich ist.

Der auth-service muss technische und organisatorische Maßnahmen zum Schutz personenbezogener Daten umsetzen.

Der auth-service muss Datenschutz durch Technikgestaltung und durch datenschutzfreundliche Voreinstellungen unterstützen.

Der auth-service muss sicherstellen, dass nur berechtigte Benutzer, Rollen oder Systeme Zugriff auf personenbezogene Daten erhalten.

### 11.7.1 Pflichtregeln

| Bereich             | Muss gelten                                                                        |
|---------------------|------------------------------------------------------------------------------------|
| Datenminimierung    | Es dürfen nur erforderliche Daten verarbeitet und gespeichert werden               |
| Zweckbindung        | Daten dürfen nur für den definierten Zweck verwendet werden                        |
| Zugriffsschutz      | Zugriff auf personenbezogene Daten muss rollenbasiert und kontrolliert erfolgen    |
| Maskierung          | sensible Daten müssen, wo möglich, maskiert werden                                 |
| Logging             | personenbezogene und geheime Daten dürfen nicht unzulässig geloggt werden          |
| Verschlüsselung     | schützenswerte Daten müssen angemessen geschützt gespeichert und übertragen werden |
| Löschbarkeit        | Daten müssen gemäß fachlicher und rechtlicher Vorgaben löschar sein                |
| Aufbewahrung        | Daten müssen mit definierten Aufbewahrungsfristen geführt werden                   |
| Nachvollziehbarkeit | datenschutzrelevante Zugriffe und Änderungen müssen auditierbar sein               |
| Support-Zugriffe    | müssen datensparsam, zweckgebunden und vollständig auditiert erfolgen              |

### 11.7.2 Besonders schützenswerte oder geheime Daten

| Datenart                          | Darf nicht ungeschützt gespeichert oder geloggt werden |
|-----------------------------------|--------------------------------------------------------|
| Passwörter                        | Ja                                                     |
| Tokens                            | Ja                                                     |
| Refresh-Tokens                    | Ja                                                     |
| Reset-Tokens                      | Ja                                                     |
| Verifikationstokens               | Ja                                                     |
| API-Keys                          | Ja                                                     |
| Secrets                           | Ja                                                     |
| Client-Secrets                    | Ja                                                     |
| TOTP-Secrets                      | Ja                                                     |
| vollständige Authorization-Header | Ja                                                     |

### 11.7.3 Löschregeln

| Bereich                           | Muss gelten                                                              |
|-----------------------------------|--------------------------------------------------------------------------|
| abgelaufene temporäre Daten       | müssen automatisch bereinigt werden                                      |
| nicht mehr benötigte Prozessdaten | müssen gelöscht oder archiviert werden                                   |
| Recovery- und Verifikationstokens | müssen nach Nutzung oder Ablauf gelöscht oder unbrauchbar gemacht werden |
| temporäre Registrierungsdaten     | müssen nach Fristablauf bereinigt werden                                 |
| technische Fehlerdaten            | müssen nach Aufbewahrungsregel bereinigt werden                          |
| Protokolldaten                    | müssen nach definierten Fristen gelöscht oder archiviert werden          |

### 11.7.4 Betroffenenrechte

| Bereich      | Muss gelten                                              |
|--------------|----------------------------------------------------------|
| Auskunft     | Daten müssen auffindbar und zuordenbar sein              |
| Berichtigung | korrigierbare Daten müssen aktualisierbar sein           |
| Löschung     | löschar Daten müssen entfernbar oder anonymisierbar sein |

| Bereich             | Muss gelten                                                             |
|---------------------|-------------------------------------------------------------------------|
| Einschränkung       | Verarbeitungsstatus muss steuerbar sein, sofern fachlich relevant       |
| Nachvollziehbarkeit | Änderungen und Löschvorgänge müssen nachvollziehbar dokumentierbar sein |

## 13.12. Tests und Abnahmekriterien

### 12.1 Tests

Der auth-service muss für alle Funktionen positive und negative Tests besitzen.

| Testbereich                | Muss vorhanden sein |
|----------------------------|---------------------|
| Positivtests               | Ja                  |
| Negativtests               | Ja                  |
| Controller-Tests           | Ja                  |
| Security-Tests             | Ja                  |
| Validierungs-Tests         | Ja                  |
| Integrations-Tests         | Ja                  |
| Datenbank-Tests            | Ja                  |
| JWT-Contract-Tests         | Ja                  |
| Idempotency-Tests          | Ja                  |
| Swagger-/OpenAPI-Prüfungen | Ja                  |

Der auth-service muss folgende Testumgebungen unterstützen:

| Testmodus      | Muss unterstützt werden |
|----------------|-------------------------|
| Testcontainers | Ja                      |
| H2             | Ja                      |

| Regel                    | Muss gelten                       |
|--------------------------|-----------------------------------|
| Tests mit Docker         | müssen unterstützt werden         |
| Tests ohne Docker        | müssen möglich sein               |
| H2-basierte Tests        | müssen ohne Docker lauffähig sein |
| andere Services in Tests | müssen mockbar oder stubbar sein  |

### 12.2 Abnahmekriterien

| Kriterium                       | Muss erfüllt sein                                                               |
|---------------------------------|---------------------------------------------------------------------------------|
| API-Port                        | AUTH_SERVER_PORT läuft standardmäßig auf 8101                                   |
| Management-Port                 | AUTH_MANAGEMENT_SERVER_PORT läuft standardmäßig auf 8201                        |
| produktive Datenbank            | nur MySQL oder MariaDB                                                          |
| Persistenztechnologie           | nur JPA / Hibernate                                                             |
| JDBC                            | wird nicht verwendet                                                            |
| MongoDB                         | wird nicht verwendet                                                            |
| Konfigurationsprinzip           | alle relevanten Konfigurationen erfolgen ausschließlich über Umgebungsvariablen |
| Port-Konfiguration              | erfolgt ausschließlich über Umgebungsvariablen                                  |
| Datenbank-Konfiguration         | erfolgt ausschließlich über Umgebungsvariablen                                  |
| JWT-Konfiguration               | erfolgt ausschließlich über Umgebungsvariablen                                  |
| MFA-Konfiguration               | erfolgt ausschließlich über Umgebungsvariablen                                  |
| E-Mail-/SMS-Kanal-Konfiguration | erfolgt ausschließlich über Umgebungsvariablen                                  |

| Kriterium                     | Muss erfüllt sein                                                             |
|-------------------------------|-------------------------------------------------------------------------------|
| Social-Login-Konfiguration    | erfolgt ausschließlich über Umgebungsvariablen                                |
| Downstream-Service-URLs       | erfolgen ausschließlich über Umgebungsvariablen                               |
| Swagger-Dokumentation         | für alle Controller, DTOs und Enums vollständig vorhanden                     |
| Registrierung                 | legt PENDING-Benutzer, PENDING-Company und PENDING-Location an                |
| Registrierung                 | stößt einen E-Mail-Bestätigungsprozess an                                     |
| Aktivierung                   | erfolgt erst nach E-Mail-Verifikation und TOTP, wenn MFA aktiviert ist        |
| Login                         | unterstützt Passwort, Google und Facebook                                     |
| Social Registrierung Google   | funktioniert                                                                  |
| Social Registrierung Facebook | funktioniert                                                                  |
| Social Login Google           | funktioniert                                                                  |
| Social Login Facebook         | funktioniert                                                                  |
| MFA nach Login                | funktioniert entsprechend Konfiguration                                       |
| TOTP                          | wird unterstützt                                                              |
| E-Mail-Kanal                  | ist konfigurierbar                                                            |
| SMS-Kanal                     | ist konfigurierbar                                                            |
| Passwort-Wiederherstellung    | stößt einen E-Mail-Wiederherstellungsprozess an                               |
| MFA-Recovery                  | unterstützt Recovery per E-Mail oder SMS                                      |
| Sessions                      | 24h- und 3-Monats-Session funktionieren                                       |
| Logout                        | widerruft die aktuelle Session                                                |
| Passwort-Reset                | funktioniert                                                                  |
| JWT                           | entspricht dem IAM-Contract                                                   |
| JWKS                          | liefert gültige Public Keys                                                   |
| Integration                   | auth, company, user und iam sind technisch verbunden                          |
| Betriebsverhalten             | Service bleibt startbar, auch wenn Docker oder andere Services nicht laufen   |
| Logging                       | strukturiert, auditierbar und ohne unzulässige sensible Daten umgesetzt       |
| Support-Diagnose              | getrennt, datensparsam und auditierbar umgesetzt                              |
| Datenschutz                   | Löschregeln, Aufbewahrung und Betroffenenrechte sind technisch berücksichtigt |
| Testabdeckung                 | alle Funktionen sind positiv und negativ abgesichert                          |